

Eduard Lara

Eduard Lara

Resumen y objetivos

ESTADO DEL ARTE

- La expansión y popularidad de las denominadas IoT, añadido a los procesos y servicios que proporciona, cada vez mas sofisticados, hacen que sea un objetivo cada vez mas apetecible para los ciberdelicuentes, de modo que la seguridad se convierte en una prioridad en estos sistemas
- Dispositivos interconectados y con capacidad de toma de decisiones
- Intervención en sistemas cada vez más complejos y con operativas más críticas
- Garantizar operativa e integridad de los datos

Resumen y objetivos

Objetivos

- Definir sistema IoT y modelar un sistema concreto
- Estudio de debilidades, riesgos y amenazas
- Para mitigar o mantener bajo control la debilidades del sistema se elabora una guía con las mejoras prácticas a tener en cuenta
- Estudio de vulnerabilidades presentes en el sistema
- Adquirir perspectiva global de un sistema IoT complejo y de la importancia de la seguridad en estos sistemas
- Plantear estrategias que sirvan para paliar o mitigar los problemas

1. Definición de IOT

Concepto de IoT:

- Interconexión de objetos entre ellos o a través de una red como Internet.
- Existen dos tipos:
 - Sensores que capturan o adquieren datos
 - Actuadores que de acuerdo a los datos recogidos, ejecutan una acción o toman una decisión

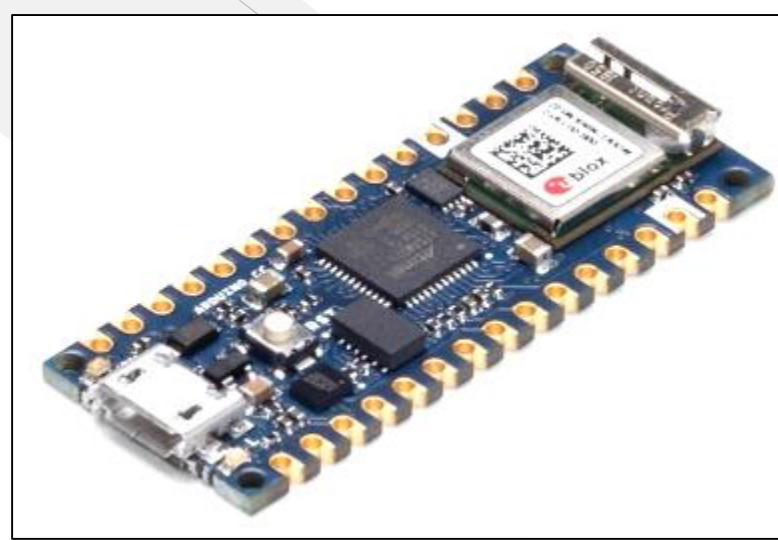
1. Definición de IOT

Evolución tecnológica hacia sistemas IoT

- SoC o chips electrónicos, de tamaño reducido
- Smartphones, funcionan como catalizador IoT
- Redes inalámbricas, facilita la comunicación entre dispositivos pero también facilita la tarea a los ciberdelincuentes
- DIY, popularización de Arduino y Raspberry. Gran comunidad usuarios
- Proliferación de dispositivos IoT (previsión de > 30 mil M para 2020)

Características de una IoT

- Comunicaciones
- Gestión y procesamiento de datos



1. Definición de IOT

Importancia de la seguridad en IoT

- Debido a su proliferación suponen un objetivo para los ciberdelincuentes,
- Es primordial reforzar la seguridad para prevenir o mitigar esos ataques en caso que prosperen.

Vectores de ataques más frecuentes

- Fuerza bruta con el descubrimiento de contraseñas
- Denegación de servicio que impiden al sistema realizar su función o dar servicio
- Acceso a un nodo de la red
- Obtención o interceptación de datos.

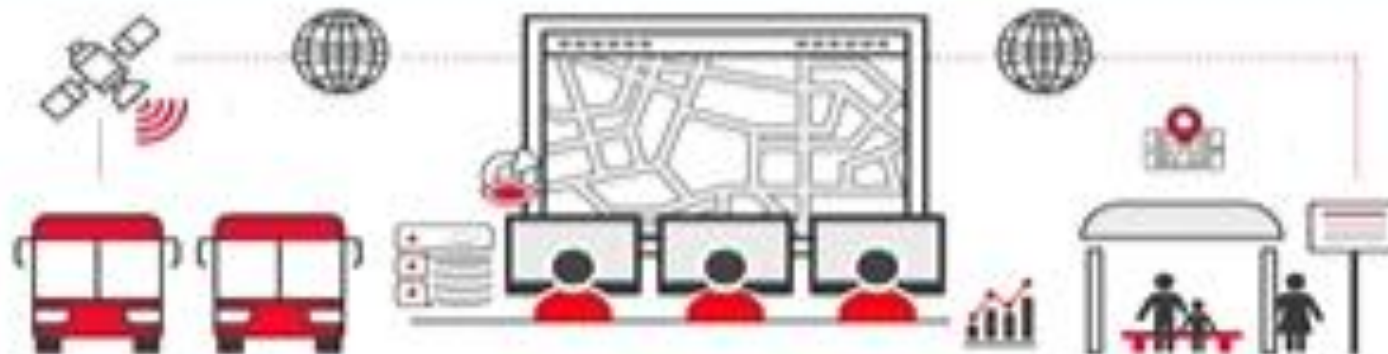
1. Definición de IOT

Algunas tipologías de sistemas IoT:

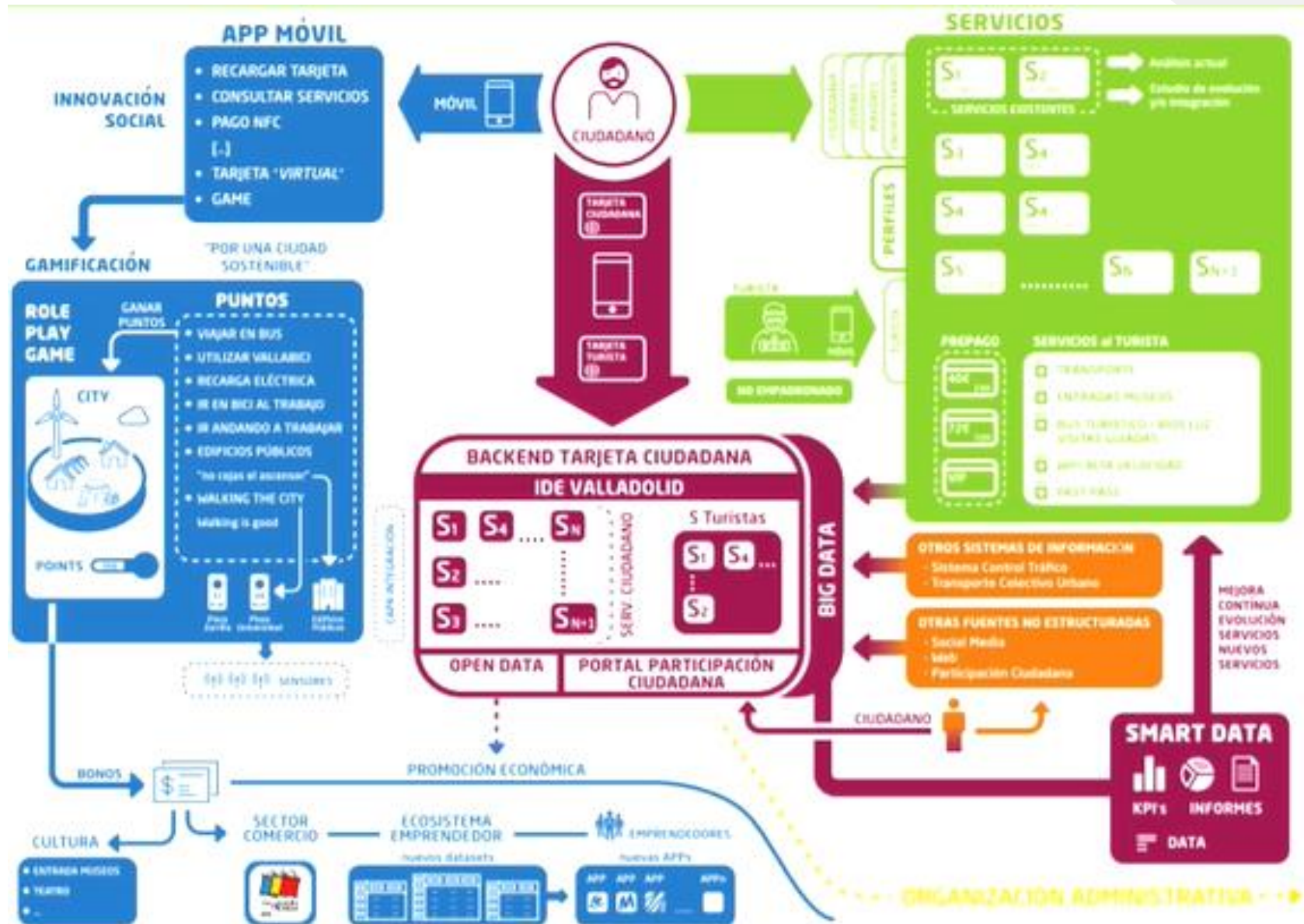
- **Industrial IoT:** IIoT, relacionado con la Industria 4.0
- **Smart City:** Proyectos en los que se digitalizan y automatizan los servicios proporcionados por una metrópoli como: el transporte urbano, el préstamo de bicicletas, el uso de bibliotecas municipales, etc..
- **Smart Home:** HomeCinema, CastingVideo, bombillas y termostatos inteligentes
- **Connected car:** con mejoras año tras año en los vehículos convencionales y el coche autónomo como paradigma de estos sistemas, que será una realidad comercial en los próximos años

1. Definición de IOT

- **IoT de transportes:** Para la gestión de flotas de vehículos, controlar la ubicación en tiempo real de los vehículos y la forma de conducir de los conductores, comunicación entre vehículo y vehículo o con el centro de control, o información de usuario en paneles o aplicaciones en smartphones
- **Smart Agriculture:** añaden tecnología para mejorar la eficiencia en los procesos necesarios en una explotación agrícolas como el riego automático controlando la humedad del suelo o la temperatura



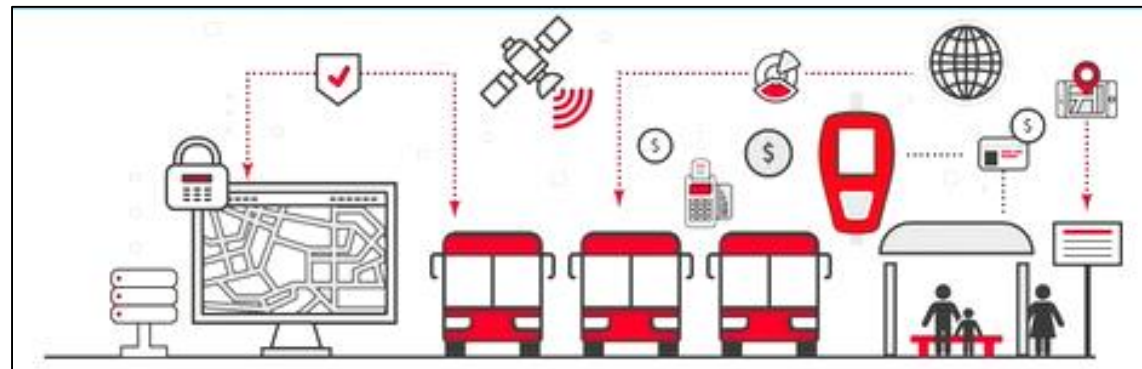
1. Definición de IOT



2. Modelado de IOT

Modelado del sistema IoT de transporte:

- Han evolucionado mucho en la ultima década
- Se están centrando en mejorar la calidad del servicio y aportar valores extra para mejorar el confort del viajero,
- La modernización de muchas flotas de transporte. Se ha pasado de utilizar radio para comunicar vehículo con vehículo, a usar GSM para llamadas y datos móviles 4G o 5G para llamadas entre vehículos sobre voz IP y también con el centro de control



2. Modelado de IOT

- Soporte de ventas de billetes nuro de inventario, como el papel o billete magnético , modelizar código QR, web services, tarjeta RFID o contactless, tecnología NFC de los teléfonos móviles o pago con tarjeta bancaria.
- Las interfaces entre sus sistemas son cada vez mas fuertes y su operativa mas sofisticada, de modo que requiere que los procesos y lass fases de desarrollo e implantación sean mas exigentes teniendo en cuenta la seguridad como elemento mas primordial
- Evolución tecnológica: se implementan por redes inalámbricas que pueden ser pirateadas y pueden alterar el servicio a miles de usuarios



2. Modelado de IOT

Componentes de sistema IoT de transporte

- Sistema de información al usuario (SIU)
 - SIUV del vehículo
 - SIUP de la parada
- Sistema de Ayuda a la Explotación (SAE), permite geolocalizar el vehículo
- Sistema de Validación y Venta (SVV), punto de entrada al sistema de pago
- Centro de control (CC), que es el gestiona todos los sistemas



Modelado de IOT

Características más importantes

- Opera en una Red 4G con IP pública
- Subsistema de vehículo:
 - SIUV, que gestiona el control de altavoces, y los dispositivos de almacenamiento masivo y contenido multimedia que se actualiza a través del centro de control.
 - SAE (Sistema de ayuda a la explotación) que gestiona la geolocalización del vehículo en un mapa y el envío de mensajería al centro de control.
 - SVV (Sistema de validación y venta) punto de entrada al sistema de dinero. Sistema critico que debe de estar perfectamente diseñado. Los soportes admitidos son: Mifare Classic, Desfire SAM, Android HCE, EMV o pago con tarjeta bancaria, soporte papel, QR)

Modelado de IOT

- Subsistema de la parada: SIUP. Permite a los usuarios ver cual es el tiempo estimado de llegada para el bus que están esperando (marquesina)
- Routers con firewall en vehículos u SIUP. Mejor implementados posibles para suponer un mejor efecto disuasorio contra los ciberdelincuentes.
- Interconexión de subsistemas: A través del centro de control. No hay conexión directa entre vehículo y vehículo, o entre vehículo y parada (SIUP). Se realiza a través de un protocolo abierto basado en estándar Transmodel, al cual se le añade seguridad de cifrado al contenido del canal del mensaje (3DES) y una firma para comprobar integridad mensaje (MD5)
- Centro de Control opera con Windows Server 2019 y w10 (operadores).
- Equipos embarcados operan con GNU/Linux: kernels 2.6.35 SIUP de la parada con hardware mas viejo y 4.9.218 opera en el resto de equipos

Estudio de amenazas y riesgos

Definición de debilidad, vulnerabilidad, amenazas y riesgo

- Debilidad es un punto débil del sistema
- Vulnerabilidad es una debilidad recogida en los sistemas de referencia de vulnerabilidades como CVE O BackTrack
- Amenaza: Toda acción que aprovecha una debilidad del sistema
- Riesgo: Probabilidad de que se produzca un incidente de seguridad, materializándose una amenaza
- Se tienen en cuenta dos baremos:
 - Probabilidad de que ocurra
 - Gravedad a nivel de afectación del sistema con respecto al riesgo

Estudio de amenazas y riesgos

Debilidades y ataques más importantes que afectan al sistema modelado:

- Red 4G con IP publica → Se puede realizar un ataque de DoS (denegación de servicio) de conexión a dicha red, a través de reintentos masivos de conexión a IPs de dicha subred. Se acaba la tarifa de datos contratada con operador y provoca la ralentización/bloqueo del trafico
- Uso de protocolos abiertos → Facilita que atacantes puedan espiar el contenido de los paquetes (Sniffing). Se cifra el contenido de cada mensaje, por lo que en principio estaría protegido
- Tecnología Mifare Classic → Descubrimiento de claves y acceso (lectura/escritura) al contenido de la tarjeta. Un atacante podría hacer una aplicación que permitiera hacer recargas a mitad de precio
- Tecnología EMV → Pago del servicio con tarjetas sin fondo. Necesita que se habilite la conexión con la red bancaria

Estudio de amenazas y riesgos

Análisis de casuísticas y posibles soluciones

- **Ataques a la red 4G.** Se pueden mitigar modificando la topología, a través del uso de VPN o Proxies que camuflen esa topología. Operador móvil tiene cierta responsabilidad e interés por protegerse.
- **Intentos de fraude technologies SVV:** Mejorar robustez del sistema SVV (diversificación de claves, migración de claves, numeración de billetes, inspecciones más frecuentes, etcètera).

Guía de mejores practicas

Dominios de seguridad de las personas

- Son dominios de personas en donde se tratan de establecer directrices con las personas involucradas en el sistema: Usuarios finales, controladores, conductores, interventores, supervisores, personal de la empresa proveedora
- Se establecerán formaciones para dar a conocer la política de seguridad y practicas que permitan que el trabajo se realiza de forma segura.
- Se establecerá una clara Asignación de roles, de modo que cada persona tenga los privilegios para realizar su labor

Guía de mejores practicas

Dominios de seguridad en los procedimientos

- Centrado en los Procedimientos o practicas llevados a cabo durante las fases del ciclo de desarrollo del sistema (OSDF):
 - Gestión de operaciones con la creación de un sistema de gestión de seguridad de información (SGSI), con un plan de gestión de incidencias, gestión de cambios donde se analice el impacto del sistema a realizar cada cambio, un sistema de versiones y parches de seguridad que están íntimamente relacionados con las debilidades de seguridad del sistema
 - Seguridad en las fases SLDC: Se considera la seguridad un requisito fundamental en todas las fases: Análisis y diseño, Desarrollo e implementación, Testing y aceptación, mantenimiento y entrega. Se priorizara la detección de cualquier problema de seguridad en las primeras fases, donde hay mas margen de maniobra para el diseño

Guía de mejores practicas

- Procedimientos corporativos de seguridad donde se establecen planes para comunicar las medidas de seguridad al personal , se realice un control para evitar revelación de información y se establezcan mecanismos para permitir la disponibilidad a todo el personal autorizado al acceso a la documentación de empresa y a comunicados oficiales

Guía de mejores practicas

- **Dominio de seguridad de las Tecnologías**
 - Control de Acceso, con medidas de robustez de credenciales y almacenamiento seguro
 - Control de actualizaciones y aplicación de parches a software de terceros
 - Comunicaciones seguras. Protocolos de comunicación cifrados
 - Programación de código seguro
 - Control anti-fraude. Mitigar o controlar el fraude
 - Revisiones de seguridad y auditorias
 - Seguridad en todas las fases del proyecto. Ver si es necesario replantear algún diseño o componente

Estudio de vulnerabilidades

- Sistemas CVE, Bugtraq, Se usaran Buscadores de vulnerabilidades como NVD, CVE Details (CVE/Bugtraq + CVSS). Se usará un sistema de puntuación de vulnerabilidad que permita dar una idea de la gravedad de la vulnerabilidad CVSS. Mientras mas grave es mas puntuación tiene hasta 10 que es critica
- Elementos más vulnerables del sistema:
 - Sistemas operativos (Windows, GNU/Linux)
 - Windows 10 1111 Vulnerabilidades
 - Windows Server 2019 405 Vulnerabilidades
 - GNU/Linux 2.6.35.2 230 Vulnerabilidades
 - GNU/Linux 4.9.218 68 Vulnerabilidades

Estudio de vulnerabilidades

- Firmware de Routers:
 - RUT950 Teltonika: 3 Vulnerabilidades, pero CVE-2017-8116 (CVSS 10.00 CRITICAL): si versión $\leq$ 00.03.265, se pueden ejecutar comandos remotos con permisos de root (ejecución remota de código + escala de privilegios)
- Protocolos y Servicios:
 - SSHv2: CVE-2002-1645, en versiones para cliente de Workstations entre 3.1 y 3.2.1 se puede ejecutar código arbitrario a través de una URL larga.

Observaciones: Se solucionan fácilmente instalando otro software. Este estudio se ha de hacer en las fases iniciales de la implantación del sistema

Conclusiones y trabajo futuro

Conclusiones

- La seguridad en los sistemas IoT es primordial y se ha de tener en cuenta en todas las fases SLDC
- Es inevitable introducir agujeros de seguridad por las restricciones del contrato. Se deben buscar soluciones para minimizar riesgos
- Negociar con el contratista para poder alterar las condiciones del contrato teniendo en cuenta que pueden suponer un problema de seguridad
- Elaboración de guía de mejores prácticas y estudio de vulnerabilidades antes de implantar el proyecto; en ese caso daría a adaptar el diseño si resulta necesario

Conclusiones y trabajo futuro

Trabajo futuro

- Realizar el estudio profundizando en otros sistemas IoT, como Smart Homes, Smart Agriculture o Connected car.
- Implementar de forma practica y sencilla un sistema IoT, investigar debilidades, amenazas, riesgos, y vulnerabilidades
- Crear y aplicar exploits para observar las consecuencias. Comprobar si tras aplicar las mejoras indicadas en la guía, el sistema queda protegido ante estos exploits
- Investigar que otras mejoras se pueden introducir para obtener un sistema IoT mejorado. Comprobar si el sistema resultante presenta debilidades y que costaría implementar mejoras para obtener una tercera iteración de sistema IoT aun mas robusto a ciberataques